

Cronograma de Entrega Final — Bah Delivery

Engenharia de Software Seguro · Etapas 2 a 7 · Segunda 10/08 a Sexta 14/08 de 2026 · 6 integrantes

Premissas. A divisão de papéis já acordada para a Etapa 2 é mantida, e os números de 1 a 6 usados neste documento são os mesmos daquela divisão. **Todos os seis integrantes participam de todas as etapas**, sem exceção. Todo o trabalho escrito ocorre de segunda até a manhã de sexta, com cerca de 2h30 por pessoa ao dia. **A única reunião é a gravação do vídeo**, na tarde ou noite de sexta — o alinhamento diário é feito por mensagem no grupo. A gravação é em tomada contínua, com apenas pequenos cortes.

Situação real. Na Etapa 1 os seis integrantes já possuem commits — essa exigência está cumprida. Na Etapa 2, os integrantes 1 e 2 já entregaram; o integrante 3 ainda não começou e, com ele, estão parados os integrantes 4, 5 e 6.

O maior risco deste cronograma não é o volume de trabalho: é a espera. A divisão da Etapa 2 é uma cadeia sequencial (1 → 2 → 3 → 4 e 5 → 6). Ela funcionaria com duas semanas; com quatro dias e meio, significa quatro pessoas ociosas hoje. As duas seções seguintes existem para quebrar essa cadeia.

Como quebrar a dependência da Etapa 2

Espera assumida	Por que ela não é real	O que fazer
Integrante 4 (NIST) espera o 3	Apresentar as seis funções não depende de nada. E o mapeamento risco → função depende dos <i>riscos</i> , que já estão prontos, não da ordem de prioridade deles	Integrante 4 começa hoje
Integrante 5 (controles) espera o 3	O controle decorre do risco e da vulnerabilidade, não do ranking. Além disso, praticamente todos os riscos terão estratégia “Reduzir”	Integrante 5 começa hoje adotando “Reduzir” como padrão; o integrante 3 confirma ou corrige as exceções depois
Integrante 5 espera o NIST do 4	É mais natural no sentido inverso: primeiro se define o controle, depois se identifica a qual função ele pertence	Integrante 5 marca as funções provisoriamente; o integrante 4 valida ao consolidar
Integrante 6 espera todos	Só a ordem de implementação e o residual dependem dos controles. A revisão de coerência e a estrutura das tabelas podem ser feitas antes	Integrante 6 começa hoje pela revisão e pelas tabelas vazias

Regra de escalonamento — combinem isso hoje, por mensagem. Se até **terça de manhã** o integrante 3 não tiver feito nenhum commit de priorização, o **integrante 6 assume** a priorização e as estratégias, e o integrante 3 é realocado para outras fatias da semana. Isso não é punição: é o que impede que o atraso de uma pessoa trave outras quatro. Sem essa regra combinada previamente, alguém vai descobrir na quinta-feira que a Etapa 2 nunca fechou.

Matriz de participação — todos os seis em todas as etapas

Cada etapa foi fatiada em exatamente seis partes. Nenhuma fatia é decorativa: todas correspondem a itens que o enunciado exige explicitamente. Cada célula equivale a algo entre 30 e 60 minutos de trabalho e a pelo menos um commit próprio.

	Etapa 3 — Arquitetura segura	Etapa 4 — Código seguro	Etapa 5 — Verificação	Etapa 6 — Detecção	Etapa 7 — DevSecOps
Integrante 1 (Arthur)	Requisito RS01 + vulnerabilidade catalogada correspondente	Prática 2 — os 2 testes, escritos antes da implementação	Análise do achado A01	Regra de detecção 1	Pipeline: Planejamento e Requisitos/arquitetura
Integrante 2 (Mariana)	Requisito RS02 + vulnerabilidade catalogada correspondente	Prática 1 — os 2 testes, escritos antes da implementação	Setup do Juice Shop e do ZAP, execução e capturas de tela	Conceito: o que é detecção e a diferença entre prevenir e detectar	Pipeline: Implementação segura e Testes automatizados
Integrante 3	Requisito RS03 + vulnerabilidade catalogada correspondente	Prática 2 — implementação ou pseudocódigo	Análise do achado A02	Regra de detecção 2	As 3 condições que impedem a continuidade do pipeline
Integrante 4	Diagrama da arquitetura segura (fonte + imagem)	Prática 1 — implementação ou pseudocódigo	Análise do achado A03	Regra de detecção 3	Pipeline: Análise de código e dependências, e Teste dinâmico
Integrante 5	Decisões de arquitetura 1 e 2	Prática 1 — resultado esperado e referência OWASP	Ambiente testado, ferramenta e configuração do teste	Quais eventos do sistema devem ser registrados	Pipeline: Implantação, e Monitoramento e resposta
Integrante 6	Decisão de arquitetura 3 e consolidação da etapa	Prática 2 — resultado esperado e referência OWASP	Limitações e possíveis falsos positivos	O que acontece depois de um alerta	Roteiro do vídeo final

Duas fatias que parecem menores, mas não são. “Limitações e falsos positivos” (Etapa 5, integrante 6) e “o que acontece depois de um alerta” (Etapa 6, integrante 6) são *critérios de avaliação explícitos* do enunciado — “capacidade de reconhecer limitações e possíveis falsos positivos” e “coerência das respostas”. Não são preenchimento para completar seis nomes.

Ordem obrigatória dentro da Etapa 4. O enunciado exige que os testes sejam escritos *antes* da implementação, e isso é avaliado. Logo, em cada prática a ordem é: testes (integrantes 1 e 2) → pseudocódigo (integrantes 3 e 4) → resultado esperado e referência OWASP (integrantes 5 e 6). O cronograma abaixo já respeita essa sequência, e os commits precisam sair nessa ordem para que o histórico comprove a prática.

Resumo da carga horária

Dia	Por pessoa	Total	Foco do dia
Segunda 10/08 (hoje)	2h00	12h	Destruar a Etapa 2 em paralelo; integrantes 1 e 2 avançam
Terça 11/08	2h30	15h	Fechar priorização, NIST e controles; setup do ZAP
Quarta 12/08	2h30	15h	Consolidar a Etapa 2; Etapas 3 e 4 e execução do scan
Quinta 13/08	2h30	15h	Etapas 5 e 6, fim da 3 e da 4, roteiro do vídeo
Sexta 14/08 — manhã	2h00	12h	Etapa 7, revisão final e ensaio individual
Sexta 14/08 — tarde/noite	1h30	9h	Gravação do vídeo, cortes leves e entrega
Total	≈ 13h00	≈ 78h	Sete etapas, com os seis integrantes em todas

Segunda 10/08 — 2h por pessoa · ninguém espera ninguém

Quem	Tarefa de hoje
Integrante 3	Prioridade máxima do grupo. Começar o ranking dos 17 riscos e as estratégias. Não precisa terminar hoje — precisa <i>começar</i> e fazer um commit, para os demais saberem que a cadeia andou
Integrante 4	Etapa 2 — seção das seis funções do NIST, com a distinção entre função, resultado esperado e controle. Iniciar o mapeamento pelos cinco riscos críticos
Integrante 5	Etapa 2 — controles, responsáveis e evidências dos críticos R07, R08, R09, R11 e R13 , adotando “Reduzir” como estratégia provisória
Integrante 6	Etapa 2 — revisão de coerência e montagem das tabelas vazias de ordem de implementação e de risco residual, com os 17 IDs preenchidos
Integrante 1	Etapa 2 — fechar as duas pendências registradas na seção 4 do documento: coluna “ Vulnerabilidade ou condição ” e tabela de classificação do nível
Integrante 2	Etapa 4 — os 2 testes da prática 1 (consultas parametrizadas e validação de entrada, ligada a R13). Escritos antes de qualquer implementação, abrindo a cadeia da Etapa 4

A única mensagem de alinhamento de hoje. Sem calls, alguém precisa publicar no grupo, em uma mensagem: (1) que os integrantes 4 e 5 começam *sem esperar* o 3; (2) que “Reduzir” é a estratégia padrão provisória; (3) a regra de escalonamento de terça de manhã; (4) a matriz de participação desta página. Sem isso, as quatro pessoas continuam esperando por educação.

Terça 11/08 — 2h30 por pessoa

Quem	Tarefa
Integrante 3	Prazo final: priorização completa dos 17 riscos, justificada por consequência, número de usuários, importância do ativo e possibilidade de recuperação — não apenas pela pontuação. Mais as estratégias justificadas
Integrante 4	Etapa 2 — concluir o mapeamento dos 17 riscos para as seis funções, analisando cada marcação. O enunciado alerta contra marcar tudo automaticamente
Integrante 5	Etapa 2 — plano de tratamento dos 12 riscos restantes. Reaproveitar controles: MFA cobre R01, R02 e R11; validação no servidor cobre R04 e R13; log íntegro cobre R06 e R12
Integrante 6	Etapa 2 — iniciar a ordem de implementação, já possível com os controles dos críticos entregues ontem
Integrante 1	Etapa 3 — requisito RS01 e a vulnerabilidade catalogada correspondente (CWE / OWASP) · Etapa 4 — os 2 testes da prática 2 (autorização no servidor, ligada a R11 e R16)
Integrante 2	Etapa 5 — subir o OWASP Juice Shop e instalar o ZAP. Antecipado por ser a única tarefa que pode falhar por motivo técnico: Docker, Java, portas

Checkpoint de terça de manhã: verificar o commit do integrante 3. Sem ele, aplicar a regra de escalonamento imediatamente, ainda pela manhã.

Quarta 12/08 — 2h30 por pessoa

Quem	Tarefa
Integrante 6	Fecha a Etapa 2: ordem de implementação justificada, risco residual com a condição de aceitação de cada um, e considerações finais. O residual é estimativa — não afirmar que o risco já diminuiu
Integrante 1	Etapa 6 — regra de detecção 1 · revisão do que já está escrito nas Etapas 2 e 3
Integrante 2	Etapa 5 — executar spider e passive scan e salvar as capturas em evidencias/etapa-5/ · Etapa 3 — requisito RS02 e sua vulnerabilidade
Integrante 3	Etapa 3 — requisito RS03 e sua vulnerabilidade · Etapa 4 — pseudocódigo da prática 2
Integrante 4	Etapa 3 — diagrama da arquitetura segura, com arquivo-fonte e imagem versionados · Etapa 4 — pseudocódigo da prática 1
Integrante 5	Etapa 3 — decisões de arquitetura 1 e 2 · Etapa 5 — descrição do ambiente, da ferramenta e da configuração do teste

Por que as capturas do ZAP saem na quarta: os integrantes 1, 3 e 4 só conseguem analisar seus achados depois que o scan rodar. Se a execução escorregar para quinta, três fatias da Etapa 5 escorregam junto.

Quinta 13/08 — 2h30 por pessoa · último dia de conteúdo pesado

Quem	Tarefa
Integrante 1	Etapa 5 — análise do achado A01: evidência, possível impacto, relação com OWASP ou CWE e correção proposta
Integrante 3	Etapa 5 — análise do achado A02 · Etapa 6 — regra de detecção 2
Integrante 4	Etapa 5 — análise do achado A03 · Etapa 6 — regra de detecção 3
Integrante 2	Etapa 6 — o que é detecção de intrusões e a diferença entre prevenir e detectar · atualização do README com a situação das sete etapas
Integrante 5	Etapa 4 — resultado esperado e referência OWASP da prática 1 · Etapa 6 — eventos que devem ser registrados
Integrante 6	Etapa 4 — resultado esperado e referência OWASP da prática 2 · Etapa 3 — decisão 3 e consolidação · roteiro do vídeo , publicado no grupo hoje à noite

Marco do dia: ao final de quinta, as Etapas 2 a 6 devem estar completas e o roteiro do vídeo publicado. Sexta de manhã fica apenas com a Etapa 7 — que é a mais mecânica — e com a revisão. Se algo maior sobrar para sexta, ele disputa espaço com a gravação, e não há dia seguinte.

Quem	Tarefa
Integrante 1	Etapas 1-7 — linhas do pipeline: Planejamento, e Requisitos e decisões de arquitetura
Integrante 2	Etapas 1-7 — linhas do pipeline: Implementação segura, e Testes automatizados
Integrante 3	Etapas 1-7 — as 3 condições que impediriam a continuidade do pipeline
Integrante 4	Etapas 1-7 — linhas do pipeline: Análise de código e dependências, e Teste dinâmico ou pentest
Integrante 5	Etapas 1-7 — linhas do pipeline: Implantação, e Monitoramento e resposta
Integrante 6	Etapas 1-7 — limitações e possíveis falsos positivos · Etapas 1-7 — o que acontece depois de um alerta · preparar as abas que serão compartilhadas na gravação, já na ordem do roteiro
Todos, ~30 min	Ler o roteiro e ensaiar a própria fala uma vez, cronometrando. Com 6 integrantes e cerca de 1 minuto cada, o vídeo fecha em 6 a 7 minutos — dentro da faixa de 5 a 8 do enunciado
Todos, ~10 min	Cada um confere no histórico que possui commits próprios nas sete etapas. É a verificação final da exigência de participação integral

Momento	O que acontece
15 min	Todos entram na call; teste rápido de áudio e de compartilhamento de tela
40 min	Gravação em tomada contínua, na ordem do roteiro. Se alguém errar, pausa e refaz apenas aquele trecho — sem reiniciar o vídeo inteiro. Todos os seis falam
20 min	Pequenos cortes: início, fim e eventuais trechos refeitos. Nada além disso
15 min	Upload, link no README, commit final e envio do endereço do repositório

Três cuidados operacionais

- Conflito de merge.** Com seis pessoas editando o mesmo arquivo Markdown ao mesmo tempo e sem calls, cada um mexe apenas na sua seção, sempre `git pull --rebase` antes do push, e commits pequenos ao fim de cada sessão em vez de um commit único no fim do dia.
- Sem calls, o grupo escrito faz a sincronização.** Ao terminar a tarefa do dia, cada pessoa avisa no grupo com uma linha. É assim que se percebe na terça que alguém travou, em vez de descobrir na sexta — que é exatamente o problema vivido hoje com o integrante 3.
- Uma fatia por pessoa por etapa é o piso, não o teto.** Quem terminar antes deve puxar a fatia seguinte para si e avisar no grupo. O cronograma tem folga real; o que ele não tem é margem para alguém entregar só na sexta.